APPLICATION SECURITY ASSESSMENT REPORT

Customer Content Management System (CCMS)

Security findings, risk analysis and remediation guidance

1	12	12	9	34
CRITICAL	HIGH	MEDIUM	LOW	TOTAL FINDINGS

Report Version	1.0
Application	Customer Content Management System (CCMS)
Technology Stack	Astro frontend (@astrojs/node ^10.1.3, @astrojs/preact ^5.1.5); Strapi 5.47.1 headless CMS backend
Framework References	github.com/withastro/astro; github.com/strapi/strapi
Assessment Type	Application security assessment — manual testing, source code review and dependency analysis
Environment	Self-hosted lab deployment
Prepared By	Faizan Ali
Classification	Public — Portfolio / Lab Assessment

> This assessment was performed against a self-hosted lab deployment of CCMS. Severity ratings reflect the assessor's judgment of likelihood and impact in that context; the risk in a production deployment depends on its configuration, exposure and compensating controls.

Contents

1 Executive Summary 3

2 Scope & Methodology 4

3 Rating Definitions 5

4 Findings Overview 6

5 Remediation Roadmap 9

6 Detailed Findings 10

7 Testing Notes & Limitations 21

8 Conclusion & Release Recommendation 22

1 Executive Summary

This report documents an application security assessment of the Customer Content Management System (CCMS), a content platform built on an Astro frontend and a Strapi headless CMS backend. The assessment identified 34 findings across authentication, session management, authorization and content workflow, browser and API security controls, input validation, third-party components, information disclosure and availability.

At the time of reporting, 19 findings are Closed, 2 are Partially Fixed and 13 remain unresolved (4 Open, 9 Not Fixed). The only Critical finding — a JWT that remained valid after logout (SEC-023) — has been closed. Eight High-severity findings are still unresolved and form the immediate remediation priority.

Findings by severity and status

Severity	Open	Not Fixed	Partially Fixed	Closed	Total
Critical	0	0	0	**1**	**1**
High	**3**	**4**	**1**	**4**	**12**
Medium	0	**3**	**1**	**8**	**12**
Low	**1**	**2**	0	**6**	**9**
Total	**4**	**9**	**2**	**19**	**34**

Key risk themes

- **Authentication hardening.** No MFA, no bot protection, a weak password policy and a non-atomic lockout counter (SEC-010, SEC-011, SEC-012, SEC-033) together leave accounts exposed to credential stuffing and password guessing.
- **Editorial workflow integrity.** An editor could publish content by omitting the status parameter (SEC-034), bypassing reviewer approval.
- **Browser-side defenses.** CSRF tokens are not properly enforced (SEC-013) and the Content Security Policy still permits inline scripts (SEC-026).
- **Dependency hygiene.** The braces finding (SEC-032) needs lockfile verification; the reported version may already be the patched release.

2 Scope & Methodology

Application	Customer Content Management System (CCMS)
Architecture	Astro server-rendered frontend (Node adapter, Preact components) backed by a Strapi 5 headless CMS API
Features in Scope	Authentication and sessions, role-based editorial workflow (editor/reviewer), media uploads, document import, snippets and variables, document tagging, AI chat assistant, HTTP/browser security controls and third-party dependencies
Testing Methods	Manual web and API testing through an intercepting proxy; source code review of frontend and backend; dependency scanning (software composition analysis)
Tools	Burp Suite; dependency scanning tooling
Environment	Self-hosted lab deployment, tested with unauthenticated and authenticated sessions across editorial roles
Out of Scope	Network and infrastructure penetration testing, social engineering, and volumetric denial-of-service or load testing
Reference Standard	Findings are mapped to the OWASP Top 10 (2021) categories

Assessment approach

1. **Reconnaissance** — Mapped routes, API endpoints, roles and the technology stack; reviewed response headers and error handling.
2. **Authentication & sessions** — Tested password policy, lockout, bot protection, MFA, session timeout, concurrency and token invalidation.
3. **Authorization & workflow** — Exercised editor/reviewer permissions, publish and delete approval gates, and direct object access to media.
4. **Input & browser controls** — Assessed validation, sanitization, CSRF, CORS, CSP and other security headers.
5. **Code & dependency review** — Reviewed security-relevant source paths and scanned dependencies for known advisories.
6. **Reporting** — Rated each finding, mapped it to OWASP Top 10 and tracked remediation status.

3 Rating Definitions

Severity

Severity	Interpretation
Critical	Potential for severe compromise or major business disruption; urgent response required.
High	Material confidentiality, integrity or availability risk; prioritize remediation.
Medium	Meaningful risk whose impact depends on context; remediate within the agreed SLA.
Low	Limited or conditional impact; address through planned hardening.

Priority

Priority	Meaning
P1	Remediate immediately; release-blocking until fixed or formally risk-accepted.
P2	Remediate within the next release cycle.
P3	Schedule through the hardening backlog.

Status

Status	Meaning
Open	Reported; remediation not yet started.
Not Fixed	Issue still present; remediation outstanding.
Partially Fixed	Mitigation applied, but the issue is not fully resolved.
Closed	Remediation implemented; issue no longer reproduced.

4 Findings Overview

Findings are listed with report-local identifiers. Each is assigned a category and mapped to the closest OWASP Top 10 (2021) risk.

ID	Finding	Category	OWASP	Severity	Status	Priority
SEC-001	Missing or Inadequate Error Pages	Information Disclosure & Logging	A05	Low	Closed	P3
SEC-002	Server Banner Information Disclosure	Information Disclosure & Logging	A05	Low	Not Fixed	P3
SEC-003	Missing or Misconfigured Security Headers	Browser & API Security	A05	Medium	Partially Fixed	P2
SEC-004	Insufficient Referrer and External-Link Controls	Browser & API Security	A05	Medium	Closed	P2
SEC-005	Vulnerable Third-Party Components	Third-Party Components	A06	Medium	Closed	P2
SEC-006	Password Policy Requirements Not Enforced	Authentication	A07	Medium	Not Fixed	P2
SEC-007	Insufficient Input Validation	Input Validation	A03	Low	Open	P3
SEC-008	Missing Login Redirect Behavior	Authentication	A07	Low	Not Fixed	P3
SEC-009	Autocomplete Enabled on Username Field	Authentication	A07	Low	Closed	P3
SEC-010	CAPTCHA or Equivalent Bot Protection Missing	Authentication	A07	High	Not Fixed	P1
SEC-011	Multi-Factor Authentication Not Implemented	Authentication	A07	High	Not Fixed	P1
SEC-012	Insufficient Password Length and Complexity	Authentication	A07	High	Not Fixed	P1
SEC-013	CSRF Token Not Randomized or Properly Enforced	Browser & API Security	A01	High	Not Fixed	P1
SEC-014	Account Lockout Threshold Misconfigured	Authentication	A07	Medium	Closed	P2
SEC-015	Concurrent Session Restrictions Not Enforced	Session Management	A07	Medium	Closed	P2
SEC-016	Session Timeout Not Enforced After Inactivity	Session Management	A07	Medium	Closed	P2
SEC-017	Broken Access Control	Authorization & Workflow	A01	High	Closed	P1
SEC-018	Unnecessary HTTP Methods Enabled	Server Configuration	A05	Medium	Not Fixed	P2
SEC-019	Web Application Firewall Not Detected	Server Configuration	A05	Medium	Not Fixed	P2
SEC-020	Regex DoS in Document Importer	Availability	A04	Medium	Closed	P2
SEC-021	Published Content Deletable Without Reviewer Approval	Authorization & Workflow	A01	High	Closed	P1

ID	Finding	Category	OWASP	Severity	Status	Priority
SEC-022	Unbounded Snippet and Variable Expansion	Availability	A04	Medium	Closed	P2
SEC-023	JWT Remained Valid After Logout	Session Management	A07	Critical	Closed	P1
SEC-024	Uploaded Media Accessible Without Authentication	Authorization & Workflow	A01	High	Closed	P1
SEC-025	Backend CORS Policy Allowed Any Origin	Browser & API Security	A05	High	Closed	P1
SEC-026	CSP Allowed Inline Scripts Without Adequate XSS Containment	Browser & API Security	A05	High	Partially Fixed	P1
SEC-027	AI Chat Logged Full User Questions and Answers	Information Disclosure & Logging	A09	Low	Closed	P3
SEC-028	Markdown Sanitizer Allowed Author-Controlled ID/Name Attributes	Input Validation	A03	Low	Closed	P3
SEC-029	Single-Session Enforcement Failed Open on Database Errors	Session Management	A04	Low	Closed	P3
SEC-030	Verbose Backend Errors Exposed to Browser	Information Disclosure & Logging	A05	Low	Closed	P3
SEC-031	Document Tags Accepted Unvalidated JSON	Input Validation	A03	Medium	Closed	P2
SEC-032	Braces 3.0.3 Dependency Reported Vulnerable to DoS	Third-Party Components	A06	High	Open	P1
SEC-033	Login Lockout Counter Not Atomic Under Parallel Attempts	Authentication	A07	High	Open	P1
SEC-034	Editor Could Publish by Omitting Status Parameter	Authorization & Workflow	A01	High	Open	P1

Findings by category

Category	Findings	Unresolved	Highest severity
Authentication	8	6	High
Session Management	4	0	Critical
Authorization & Workflow	4	1	High
Browser & API Security	5	3	High
Input Validation	3	1	Medium
Third-Party Components	2	1	High
Information Disclosure & Logging	4	1	Low
Server Configuration	2	2	Medium
Availability	2	0	Medium

OWASP Top 10 (2021) coverage

OWASP category	Count	Findings
A01:2021 Broken Access Control	5	SEC-013, SEC-017, SEC-021, SEC-024, SEC-034
A03:2021 Injection	3	SEC-007, SEC-028, SEC-031
A04:2021 Insecure Design	3	SEC-020, SEC-022, SEC-029
A05:2021 Security Misconfiguration	9	SEC-001, SEC-002, SEC-003, SEC-004, SEC-018, SEC-019, SEC-025, SEC-026, SEC-030
A06:2021 Vulnerable and Outdated Components	2	SEC-005, SEC-032
A07:2021 Identification and Authentication Failures	11	SEC-006, SEC-008, SEC-009, SEC-010, SEC-011, SEC-012, SEC-014, SEC-015, SEC-016, SEC-023, SEC-033
A09:2021 Security Logging and Monitoring Failures	1	SEC-027

5 Remediation Roadmap

Unresolved findings grouped by priority. Items within each group are listed in report order.

Immediate — P1 (8)

Remediate before any production release.

- **SEC-010** CAPTCHA or Equivalent Bot Protection Missing — High · Not Fixed
- **SEC-011** Multi-Factor Authentication Not Implemented — High · Not Fixed
- **SEC-012** Insufficient Password Length and Complexity — High · Not Fixed
- **SEC-013** CSRF Token Not Randomized or Properly Enforced — High · Not Fixed
- **SEC-026** CSP Allowed Inline Scripts Without Adequate XSS Containment — High · Partially Fixed
- **SEC-032** Braces 3.0.3 Dependency Reported Vulnerable to DoS — High · Open
- **SEC-033** Login Lockout Counter Not Atomic Under Parallel Attempts — High · Open
- **SEC-034** Editor Could Publish by Omitting Status Parameter — High · Open

Short term — P2 (4)

Remediate within the next release cycle.

- **SEC-003** Missing or Misconfigured Security Headers — Medium · Partially Fixed
- **SEC-006** Password Policy Requirements Not Enforced — Medium · Not Fixed
- **SEC-018** Unnecessary HTTP Methods Enabled — Medium · Not Fixed
- **SEC-019** Web Application Firewall Not Detected — Medium · Not Fixed

Planned hardening — P3 (3)

Schedule through the hardening backlog.

- **SEC-002** Server Banner Information Disclosure — Low · Not Fixed
- **SEC-007** Insufficient Input Validation — Low · Open
- **SEC-008** Missing Login Redirect Behavior — Low · Not Fixed

Regression (5)

Re-test closed Critical/High findings after every significant change.

- **SEC-017** Broken Access Control — High · Closed
- **SEC-021** Published Content Deletable Without Reviewer Approval — High · Closed
- **SEC-023** JWT Remained Valid After Logout — Critical · Closed
- **SEC-024** Uploaded Media Accessible Without Authentication — High · Closed
- **SEC-025** Backend CORS Policy Allowed Any Origin — High · Closed

6 Detailed Findings

Each finding includes a summary, technical detail, security risk, business impact and recommended remediation.

SEC-001 Missing or Inadequate Error Pages

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Low	Closed	P3	Information Disclosure & Logging	A05:2021 Security Misconfiguration

Issue Summary	Custom error handling was missing or inconsistent for some failed requests.
Issue Detail	Error responses may reveal default framework behavior or inconsistent messages.
Security Risk	Detailed errors can help attackers perform reconnaissance.
Business Impact	May increase support effort and weaken security assurance.
Remediation	Return generic error pages; keep diagnostics in access-controlled server logs.
Related Findings	SEC-030

SEC-002 Server Banner Information Disclosure

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Low	Not Fixed	P3	Information Disclosure & Logging	A05:2021 Security Misconfiguration

Issue Summary	HTTP responses disclosed server or framework identification.
Issue Detail	Headers or default responses may expose product or version details.
Security Risk	Attackers can target known weaknesses in identified technologies.
Business Impact	May increase targeted exploitation risk.
Remediation	Remove unnecessary Server/X-Powered-By details and normalize proxy/application responses.

SEC-003 Missing or Misconfigured Security Headers

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Partially Fixed	P2	Browser & API Security	A05:2021 Security Misconfiguration

Issue Summary	One or more recommended HTTP security headers were absent or misconfigured.
Issue Detail	Browser-side protections were not consistently enforced across responses.
Security Risk	Depending on the missing header, risk may include clickjacking, content injection, or referrer leakage.
Business Impact	Creates avoidable user and compliance exposure.
Remediation	Configure and validate CSP, HSTS, X-Content-Type-Options, Referrer-Policy, and frame-embedding controls as applicable.
Related Findings	SEC-026

SEC-004 Insufficient Referrer and External-Link Controls

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Closed	P2	Browser & API Security	A05:2021 Security Misconfiguration

Issue Summary	Referrer handling or external-navigation trust controls were insufficient.
Issue Detail	Cross-origin navigation may disclose excess referrer data or trust unsafe destinations.
Security Risk	Sensitive URL data may leak; unsafe navigation may aid phishing.
Business Impact	May expose user context and undermine trust.
Remediation	Use a restrictive Referrer-Policy, validate redirect targets, and apply safe link attributes where applicable.

SEC-005 Vulnerable Third-Party Components

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Closed	P2	Third-Party Components	A06:2021 Vulnerable and Outdated Components

Issue Summary	Third-party components were reported as vulnerable or requiring security review.
Issue Detail	Resolved dependency versions and advisory applicability must be confirmed against the deployed artifact.
Security Risk	Affected components may enable denial of service or other compromise depending on the advisory.
Business Impact	May increase incident, patching, and compliance costs.
Remediation	Scan the lockfile/SBOM, validate reachability, and upgrade to vendor-fixed versions.
Related Findings	SEC-032

SEC-006 Password Policy Requirements Not Enforced

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Not Fixed	P2	Authentication	A07:2021 Identification and Authentication Failures

Issue Summary	The application did not enforce the expected password policy.
Issue Detail	Password length or complexity controls were weaker than the defined baseline.
Security Risk	Weak passwords are easier to guess, increasing account-compromise risk.
Business Impact	Could expose user accounts and increase recovery workload.
Remediation	Enforce documented server-side password rules, block commonly compromised passwords, and apply rate limits.
Related Findings	SEC-012

SEC-007 Insufficient Input Validation

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Low	Open	P3	Input Validation	A03:2021 Injection

Issue Summary	One or more inputs accepted values without adequate validation.
Issue Detail	Type, format, length, range, or allowed-value checks may be missing server-side.
Security Risk	Malformed input may cause unexpected behavior or contribute to injection if unsafe sinks exist.
Business Impact	May affect data integrity and application stability.
Remediation	Apply allowlist-based server-side validation, size limits, normalization, and context-appropriate output encoding.

SEC-008 Missing Login Redirect Behavior

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Low	Not Fixed	P3	Authentication	A07:2021 Identification and Authentication Failures

Issue Summary	Expected HTTP 302 redirect behavior was not observed in the tested login flow.
Issue Detail	Redirect behavior may be inconsistent across successful login and unauthenticated access.
Security Risk	Security impact depends on whether access controls can also be bypassed.
Business Impact	May disrupt authentication workflow and user experience.
Remediation	Implement explicit redirect rules and independently enforce authorization on every protected resource.

SEC-009 Autocomplete Enabled on Username Field

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Low	Closed	P3	Authentication	A07:2021 Identification and Authentication Failures

Issue Summary	The username field permitted browser autocomplete.
Issue Detail	A browser may suggest or retain account identifiers on shared devices.
Security Risk	May disclose usernames to another person using the same device; this alone does not expose passwords.
Business Impact	Creates a limited privacy concern in shared-device settings.
Remediation	Set an appropriate autocomplete policy and avoid client-side storage of sensitive credentials.

SEC-010 CAPTCHA or Equivalent Bot Protection Missing

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Not Fixed	P1	Authentication	A07:2021 Identification and Authentication Failures

Issue Summary	The authentication flow lacked expected CAPTCHA or equivalent bot protection.
Issue Detail	Automated submissions may be possible unless other effective controls are present.
Security Risk	Can facilitate credential stuffing, password spraying, or account enumeration.
Business Impact	May increase account takeover, fraud, and support costs.
Remediation	Add risk-based bot protection, server-side rate limits, monitoring, and bypass-resistant controls.

SEC-011 Multi-Factor Authentication Not Implemented

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Not Fixed	P1	Authentication	A07:2021 Identification and Authentication Failures

Issue Summary	MFA was not available or enforced for the assessed authentication flow.
Issue Detail	Access relied on a single factor without an additional verification step.
Security Risk	Stolen or guessed credentials may be sufficient to access accounts.
Business Impact	Could cause unauthorized access, data exposure, and incident costs.
Remediation	Enforce MFA for privileged and sensitive accounts, with secure enrollment and recovery.

SEC-012 Insufficient Password Length and Complexity

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Not Fixed	P1	Authentication	A07:2021 Identification and Authentication Failures

Issue Summary	Password controls did not meet the required length and complexity baseline.
Issue Detail	The application accepted passwords that may be easier to guess or reuse.
Security Risk	Raises brute-force and credential-stuffing risk, particularly with weak throttling.
Business Impact	May lead to account takeover and reputational damage.
Remediation	Set a strong minimum length, screen compromised passwords, support password managers, and apply throttling/MFA.
Related Findings	SEC-006

SEC-013 CSRF Token Not Randomized or Properly Enforced

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Not Fixed	P1	Browser & API Security	A01:2021 Broken Access Control

Issue Summary	The tested state-changing flow did not demonstrate a sufficiently unpredictable and enforced CSRF token.
Issue Detail	A browser-authenticated request may be accepted without a valid session-bound token or equivalent defense.
Security Risk	An attacker may trick a logged-in user into performing unauthorized actions.
Business Impact	Could result in unauthorized changes or administrative actions.
Remediation	Use cryptographically random session-bound tokens, validate server-side, and apply suitable SameSite/origin checks.

SEC-014 Account Lockout Threshold Misconfigured

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Closed	P2	Authentication	A07:2021 Identification and Authentication Failures

Issue Summary	The account lockout threshold exceeded the configured security requirement.
Issue Detail	More failed attempts may be allowed than the approved policy permits.
Security Risk	Provides extra password-guessing opportunities; overly strict lockout can also enable denial of service.
Business Impact	Increases account-compromise or support risk.
Remediation	Align thresholds with policy and combine throttling, monitoring, and safe recovery.
Related Findings	SEC-033

SEC-015 Concurrent Session Restrictions Not Enforced

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Closed	P2	Session Management	A07:2021 Identification and Authentication Failures

Issue Summary	Concurrent sessions were not consistently restricted as required.
Issue Detail	Users may retain multiple active sessions where policy expects one.
Security Risk	A stolen session may remain usable alongside the legitimate user's session.
Business Impact	Weakens account controls and complicates incident investigation.
Remediation	Enforce session concurrency server-side and invalidate superseded sessions where required.
Related Findings	SEC-029

SEC-016 Session Timeout Not Enforced After Inactivity

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Closed	P2	Session Management	A07:2021 Identification and Authentication Failures

Issue Summary	A session remained active beyond the intended inactivity timeout.
Issue Detail	Server-side expiry did not reliably invalidate an idle session.
Security Risk	An unattended device may retain access to authenticated functions.
Business Impact	Could expose sensitive content or permit unauthorized actions.
Remediation	Enforce server-side idle and absolute expiry and test all protected routes.

SEC-017 Broken Access Control

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Closed	P1	Authorization & Workflow	A01:2021 Broken Access Control

Issue Summary	A protected resource or action was accessible without the expected authorization check.
Issue Detail	The tested role/resource path showed an authorization gap between assigned and effective permissions.
Security Risk	Users may access or modify data beyond assigned permissions.
Business Impact	May expose or alter business data and create compliance risk.
Remediation	Apply deny-by-default server-side authorization and verify ownership, role, and tenant boundaries.

SEC-018 Unnecessary HTTP Methods Enabled

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Not Fixed	P2	Server Configuration	A05:2021 Security Misconfiguration

Issue Summary	The server accepted or advertised HTTP methods not required by the application.
Issue Detail	Extra methods may expose unintended behavior; impact depends on actual method handling.
Security Risk	Unsafe methods may broaden the attack surface or permit unintended operations.
Business Impact	Creates avoidable configuration risk.
Remediation	Disable unused methods at application/proxy layers and explicitly allow required methods only.

SEC-019 Web Application Firewall Not Detected

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Not Fixed	P2	Server Configuration	A05:2021 Security Misconfiguration

Issue Summary	A WAF was not detected in the assessed deployment path.
Issue Detail	This is a defense-in-depth observation and does not alone prove an application vulnerability.
Security Risk	Removes an additional filtering layer for common web attacks and automated traffic.
Business Impact	May increase operational exposure if compensating controls are insufficient.
Remediation	Review architecture and threat model; deploy and tune a WAF if required while retaining application-level controls.

SEC-020 Regex DoS in Document Importer

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Closed	P2	Availability	A04:2021 Insecure Design

Issue Summary	A document-import pattern could trigger excessive regular-expression processing.
Issue Detail	Crafted input may consume CPU and stall the importer or frontend path.
Security Risk	May degrade availability if the affected path is reachable by an attacker.
Business Impact	Could interrupt content-import operations.
Remediation	Use safe/linear-time patterns, bound input size, add timeouts, and throttle requests.

SEC-021 Published Content Deletable Without Reviewer Approval

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Closed	P1	Authorization & Workflow	A01:2021 Broken Access Control

Issue Summary	An editor could delete published content without the expected reviewer approval.
Issue Detail	The destructive workflow bypassed the intended approval gate.
Security Risk	An editor or compromised account could remove published content without authorization.
Business Impact	May cause content loss, service disruption, and audit issues.
Remediation	Enforce approval server-side for destructive actions, separate roles, and log immutable audit events.
Related Findings	SEC-034

SEC-022 Unbounded Snippet and Variable Expansion

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Closed	P2	Availability	A04:2021 Insecure Design

Issue Summary	Snippet or variable expansion lacked adequate depth or output limits.
Issue Detail	Nested expansion may cause disproportionate memory or processing use.
Security Risk	A user of the feature may exhaust resources and affect availability.
Business Impact	Could disrupt content editing or rendering.
Remediation	Set expansion-depth/output-size limits, detect cycles, and enforce resource budgets.

SEC-023 JWT Remained Valid After Logout

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Critical	Closed	P1	Session Management	A07:2021 Identification and Authentication Failures

Issue Summary	A JWT remained usable after logout in the tested flow.
Issue Detail	Logout did not prevent continued token acceptance until expiry.
Security Risk	A copied or stolen token may continue authorizing requests after the user logs out.
Business Impact	Could enable continued unauthorized access to accounts or data.
Remediation	Use short-lived access tokens plus refresh-token revocation, or server-side revocation/token-version checks where immediate invalidation is required.

SEC-024 Uploaded Media Accessible Without Authentication

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Closed	P1	Authorization & Workflow	A01:2021 Broken Access Control

Issue Summary	Uploaded media could be retrieved without authentication in the tested configuration.
Issue Detail	Direct media URLs bypassed the expected access requirement for protected content.
Security Risk	Restricted files may be disclosed to unauthenticated users if not intended to be public.
Business Impact	Could expose confidential data and create privacy/compliance risk.
Remediation	Store private media outside public paths and serve it through authorization-checked handlers or short-lived signed URLs.

SEC-025 Backend CORS Policy Allowed Any Origin

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Closed	P1	Browser & API Security	A05:2021 Security Misconfiguration

Issue Summary	The backend CORS policy accepted arbitrary origins.
Issue Detail	If sensitive responses support credentialed cross-origin access, untrusted sites may read them in a victim's browser.
Security Risk	May expose authenticated API data when compatible credential and browser conditions exist.
Business Impact	Could cause unauthorized data disclosure and loss of trust.
Remediation	Allowlist trusted origins and restrict methods/headers; never pair arbitrary origins with credentialed access.

SEC-026 CSP Allowed Inline Scripts Without Adequate XSS Containment

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Partially Fixed	P1	Browser & API Security	A05:2021 Security Misconfiguration

Issue Summary	The CSP allowed inline scripts without sufficient XSS containment.
Issue Detail	Permissive inline-script directives weaken CSP's protection against injected script execution.
Security Risk	If an injection flaw exists, CSP may provide limited protection against XSS.
Business Impact	Could increase the impact of client-side injection and account compromise.
Remediation	Remove unsafe-inline where feasible and use nonces or hashes; validate the policy across all relevant routes.
Related Findings	SEC-003

SEC-027 AI Chat Logged Full User Questions and Answers

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Low	Closed	P3	Information Disclosure & Logging	A09:2021 Security Logging and Monitoring Failures

Issue Summary	The AI chat workflow logged complete prompts and responses.
Issue Detail	Logs may contain personal, confidential, or business-sensitive content.
Security Risk	Sensitive content may be exposed to log readers or retained longer than intended.
Business Impact	Creates privacy, retention, and compliance concerns.
Remediation	Minimize logged content, redact sensitive data, restrict access, and define retention periods.

SEC-028 Markdown Sanitizer Allowed Author-Controlled ID/Name Attributes

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Low	Closed	P3	Input Validation	A03:2021 Injection

Issue Summary	The Markdown sanitizer permitted author-controlled id and name attributes.
Issue Detail	These attributes may cause DOM clobbering in some client-side implementations; exploitability depends on downstream code.
Security Risk	Could enable UI manipulation or contribute to client-side weaknesses if code trusts clobberable DOM properties.
Business Impact	May affect interface integrity or security controls.
Remediation	Strip or strictly allowlist id/name attributes and avoid trusting attacker-controlled DOM properties.

SEC-029 Single-Session Enforcement Failed Open on Database Errors

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Low	Closed	P3	Session Management	A04:2021 Insecure Design

Issue Summary	Single-session enforcement failed open during database errors.
Issue Detail	A session restriction could be bypassed when its database dependency failed.
Security Risk	Concurrent sessions may be accepted during an error condition.
Business Impact	Weakens account policy and complicates outage investigations.
Remediation	Handle dependency failures explicitly, fail securely where appropriate, and alert on enforcement failures.
Related Findings	SEC-015

SEC-030 Verbose Backend Errors Exposed to Browser

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Low	Closed	P3	Information Disclosure & Logging	A05:2021 Security Misconfiguration

Issue Summary	Detailed internal backend errors were returned to the browser.
Issue Detail	Responses may reveal internal component names, stack traces, or implementation details.
Security Risk	Information disclosure can help attackers map the system and refine attacks.
Business Impact	May increase targeted attack risk.
Remediation	Return generic client errors and retain sanitized diagnostics in access-controlled server logs.
Related Findings	SEC-001

SEC-031 Document Tags Accepted Unvalidated JSON

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
Medium	Closed	P2	Input Validation	A03:2021 Injection

Issue Summary	The document tags field accepted arbitrary JSON without adequate schema validation.
Issue Detail	Unexpected structures, types, or oversized values may reach downstream processing.
Security Risk	May cause data integrity issues, application errors, or injection risks if values are used unsafely.
Business Impact	Could disrupt document workflows or stored-content quality.
Remediation	Validate against a strict server-side schema and enforce size/type limits.

SEC-032 Braces 3.0.3 Dependency Reported Vulnerable to DoS

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Open	P1	Third-Party Components	A06:2021 Vulnerable and Outdated Components

Issue Summary	Dependency scanning reported the braces package (3.0.3) with a denial-of-service concern.
Issue Detail	The resolved version, advisory applicability, dependency path, and attacker-controlled reachability must be confirmed.
Security Risk	If affected code is reachable, crafted input may cause excessive processing and reduce availability.
Business Impact	Could degrade or interrupt service.
Remediation	Upgrade to a vendor-fixed compatible version, regenerate the lockfile, and retest the affected path.
Analyst Note	The public advisory for braces (CVE-2024-4068) lists versions below 3.0.3 as affected and 3.0.3 as the patched release. If every copy in the lockfile resolves to 3.0.3 or later, this result is likely a scanner false positive; any nested copy resolving below 3.0.3 should be upgraded.
Related Findings	SEC-005

SEC-033 Login Lockout Counter Not Atomic Under Parallel Attempts

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Open	P1	Authentication	A07:2021 Identification and Authentication Failures

Issue Summary	Parallel failed login attempts could update the lockout counter non-atomically.
Issue Detail	Race conditions may cause missed increments or inconsistent lockout decisions.
Security Risk	An attacker may exceed the intended threshold and gain more password-guessing opportunities.
Business Impact	Weakens account protection and increases takeover risk.
Remediation	Use atomic updates or transactional counters, apply rate limits, and test concurrent attempts.
Related Findings	SEC-014

SEC-034 **Editor Could Publish by Omitting Status Parameter**

SEVERITY	STATUS	PRIORITY	CATEGORY	OWASP TOP 10
High	Open	P1	Authorization & Workflow	A01:2021 Broken Access Control

Issue Summary	An editor could publish content by omitting the status parameter.
Issue Detail	The workflow did not reliably enforce approval when the status field was absent.
Security Risk	A lower-privileged user may publish unapproved content and bypass integrity controls.
Business Impact	Could expose unreviewed content and undermine audit requirements.
Remediation	Enforce workflow transitions and reviewer authorization server-side; reject missing or invalid status values.
Related Findings	SEC-021

7 Testing Notes & Limitations

- Testing was performed against a self-hosted lab deployment. Production configuration (reverse proxy, WAF, TLS termination, hosting controls) may differ and can change the effective risk of configuration findings such as SEC-002, SEC-018 and SEC-019.
- Severity ratings are qualitative assessments of likelihood and impact in the lab context.
- Statuses reflect the remediation tracker at the time of publication. Closed findings should be included in regression testing after future changes.
- Dependency findings depend on the resolved lockfile; versions should be confirmed against the deployed build (SEC-005, SEC-032).
- Raw evidence (HTTP request/response captures, screenshots and logs) is not reproduced in this public version of the report.
- Original tracker identifiers have been replaced with report-local IDs (SEC-001 to SEC-034).

8 Conclusion & Release Recommendation

Overall Assessment	CCMS shows meaningful remediation progress — 19 of 34 findings, including the only Critical finding, are closed — but material gaps remain in authentication hardening, CSRF protection and editorial workflow enforcement.
Release Recommendation	Not ready for production release until the eight unresolved High-severity findings are remediated or formally risk-accepted.
Release-Blocking Findings	SEC-010, SEC-011, SEC-012, SEC-013, SEC-026, SEC-032, SEC-033, SEC-034
Required Next Steps	1. Remediate the P1 findings listed in the remediation roadmap. 2. Complete the partial fixes for SEC-003 and SEC-026. 3. Verify the braces dependency resolution for SEC-032. 4. Regression-test closed Critical/High findings. 5. Document any accepted risks.
Final Remarks	This report reflects the state of the application at the time of testing and is not a certification of overall application security.

Prepared by **Faizan Ali** · Report version 1.0